

Esercitazione con Event Viewer in Flare VM

Introduzione

Nell'esercitazione di oggi, viene richiesto di:

1. Accedere al Visualizzatore Eventi:

- a) Aprire il Visualizzatore eventi premendo Win + R per aprire la finestra "Esegui".
- b) Digitare eventvwr e premere Invio.

2. Configurare le Proprietà del Registro di Sicurezza:

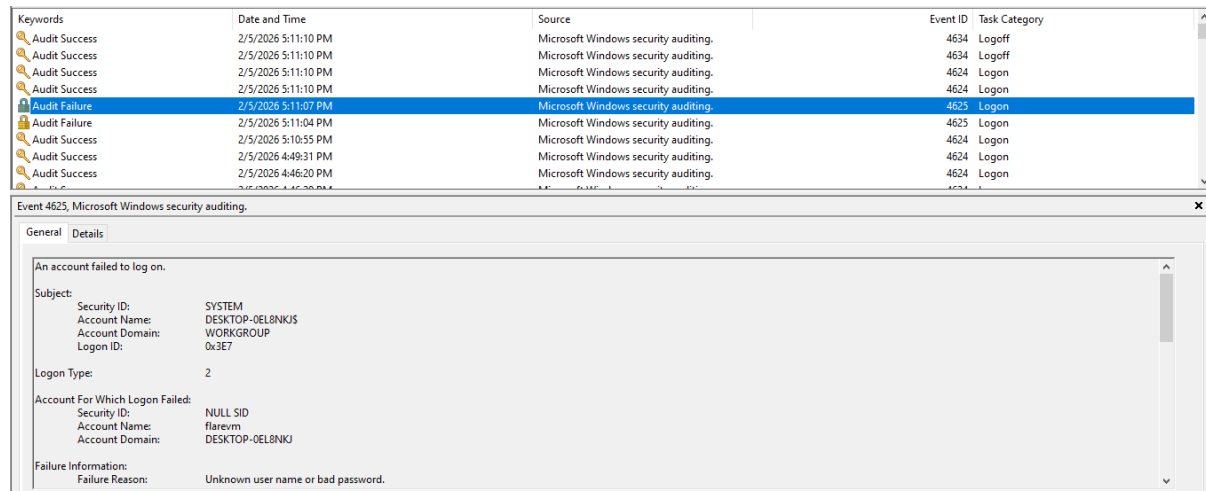
- a) Nel pannello di sinistra, espandere "Registri di Windows" e selezionare "Sicurezza".

- b) Provare ad impostare il log dei Login/Logoff.

Step 1

Una volta digitato eventvwr e aperto il visualizzatore di eventi, e selezionato "Windows Log", nel pannello sulla sinistra si utilizzerà la voce "Security"; una volta fatto ciò, vengono configurate le politiche del filtro per avere una visione di ciò che occorre, questo attraverso la voce "Filter Current Log".

Una volta selezionati i criteri, vengono visualizzate una serie 4624, ovvero di accessi effettuati andati a buon fine; c'è da dire che la macchina è scollegata da internet ed è assolutamente pulita, si prova quindi a sporcare i log inserendo password sbagliate.



Viene sporcato il registro e si nota subito il tentativo di accesso; ora bisogna capire come mai l'accesso sia stato negato, così si va all'interno della sezione "Failure Reason"

Failure Information:
Failure Reason: Unknown user name or bad password.
Status: 0xC000006D
Sub Status: 0xC000006A

- **Status: 0xC000006D (STATUS_LOGON_FAILURE)**
- È il codice generico di "Accesso Negato". Indica semplicemente che l'autenticazione non è andata a buon fine per un motivo legato alle credenziali.
- **Sub Status: 0xC000006A (STATUS_WRONG_PASSWORD)**
- Questo è il "dato tattico". Significa: **"Nome utente corretto, Password errata"**.

Conclusioni

In uno scenario di attacco reale, questa combinazione delinea quanto segue

- **Per il Difensore:** Conferma che qualcuno sta tentando di indovinare la password di un utente *esistente*. Non è uno spray casuale su nomi inventati.
- **Per l'Attaccante:** Se riceve questo codice durante un brute-force, ha appena confermato l'**Enumerazione dell'Utente**. L'account, quindi, esiste (altrimenti avrebbe generato un 0xC0000064 - User Name Not Found).

Extra

```
Detailed Authentication Information:  
Logon Process:      User32  
Authentication Package: Negotiate  
Transited Services: -  
Package Name (NTLM only): -|  
Key Length:        0
```

This event is generated when a logon request fails. It is generated on the computer where access was attempted.

Qui c'è la firma tecnica di come il sistema abbia tentato di processare la richiesta di accesso prima di fallire.

User32 fa riferimento alla libreria di sistema che gestisce l'interfaccia utente.

Il tentativo di accesso non è avvenuto tramite SMB o WMI, bensì con interfaccia grafica.

Inoltre questo è avvenuto tramite il pacchetto di autenticazione "Negotiate", istruito attraverso Kerberos.

Keylength invece attiene alla lunghezza della chiave di sessione che è 0; accesso fallito e quindi nessun tunnel; in una sessione normale sarebbe 128 (bit); standard per Kerberos.

256 invece, rappresenta la sicurezza massima: è scomodo per un attaccante e richiede molto tempo.

40 o 60; vulnerabile e a rischio bruteforce basato su LAN Manager o DES.